Enterprise Cybersecurity Risk Assessment Report

NIST Cybersecurity Framework (CSF) 2.0 | MedSecure Solutions

Assessment type: Simulated portfolio exercise • Report date: November 3, 2026

Prepared for: Fictional executive leadership and security stakeholders

Executive summary

MedSecure Solutions is a fictional healthcare services organization with approximately 100 employees. This educational assessment inventories eight technology assets and evaluates six illustrative cybersecurity risk scenarios. Using a project-defined 5×5 likelihood-impact method, one risk is Critical (cloud file exposure, score 20) and five are High (scores 12–16). These are assumptions, not findings from a real organization.

Priority actions are to restrict cloud file sharing and access; strengthen multifactor authentication and identity reviews; improve phishing training; standardize endpoint hardening; and test protected backup restoration. Seven mappings to NIST CSF 2.0 subcategories support remediation planning. No real systems, patient records, or controls were tested.

1 Organization and scope

In scope: eight sample assets including employee laptops, Microsoft 365 email, electronic health records (EHR), cloud file storage, corporate Wi-Fi, backups, employee identity accounts, and the public website. The risk scenarios focus on six of these assets. Out of scope: penetration testing, interviews, evidence validation, technical scanning, HIPAA compliance determination, and independent assurance.

2 Assessment methodology

Risks are scored as Likelihood (1–5) × Impact (1–5). Project severity thresholds: Low 1–4; Medium 5–9; High 10–16; Critical 17–25. The scoring scale and bands are illustrative project conventions and are not prescribed by NIST CSF 2.0. The risk register is the primary source of the six ratings; the heat-map workbook separately illustrates the same scenarios.

Likelihood	Impact	Score range	Classification
1–5	1–5	1–4	Low
1–5	1–5	5–9	Medium
1–5	1–5	10–16	High
1–5	1–5	17–25	Critical

3 Asset inventory overview

ID	Asset	Type	Criticality
A001	Employee Laptops	Endpoint	High
A002	Microsoft 365 Email	SaaS	High
A003	Electronic Health Records	Application	Critical
A004	Cloud File Storage	Cloud	High
A005	Corporate Wi-Fi	Network	Medium
A006	Backup System	Infrastructure	Critical
A007	Employee Identity Accounts	Identity	Critical
A008	Company Website	Web Application	Medium

Inventory summary: 3 Critical, 4 High, and 1 Medium asset. Asset owners and data classifications are fictional assignments documented in the Asset Inventory workbook.

4 Risk register findings

ID	Risk scenario	L × I	Score	Level
R001	Phishing leads to account	4 × 4	16	High

	compromise			
R002	Malware infection	3 × 4	12	High
R003	Unauthorized access to sensitive records	3 × 5	15	High
R004	Cloud permissions expose sensitive files	4 × 5	20	Critical
R005	Ransomware compromises backup availability	3 × 5	15	High
R006	Weak authentication permits unauthorized access	4 × 4	16	High

Risk distribution: 1 Critical, 5 High, 0 Medium, 0 Low. The highest-scoring scenario is R004 (cloud permissions expose sensitive files, 20/25). Ratings are inherent-style illustrative estimates and have not been adjusted for verified control effectiveness.

5 NIST CSF 2.0 gap analysis

The control-mapping workbook contains seven risk-to-outcome mappings for six risks; R001 maps to two subcategories. “Current state” and “gap” descriptions below are fictional assumptions requiring validation in any real assessment. NIST CSF subcategories describe desired outcomes, not mandatory prescriptive implementation steps.

Risk / NIST outcome	Simulated gap	Recommended action
R001 / PR.AT-01	No recurring phishing exercises or tracking	Quarterly phishing simulations; targeted training; report-button adoption
R001 / PR.AA-03	Inconsistent MFA enforcement	Require phishing-resistant MFA for privileged users; enforce MFA broadly
R002 / PR.PS-01	No standardized secure endpoint baseline	Define and enforce hardened endpoint baseline and patch schedule
R003 / PR.AA-05	Periodic access certification not documented	Quarterly role-based access reviews and removal of excess permissions
R004 / PR.DS-01	Excessive sharing and weak data access restrictions	Restrict public sharing; apply least privilege and sensitive-data controls
R005 / RC.RP-01	Recovery capability not demonstrated	Test restores quarterly; use immutable/offline backup copy
R006 / PR.AA-03	Weak authentication coverage	Enforce MFA and review legacy authentication settings

6 Remediation priorities and action plan

Priority	Suggested timeframe	Actions	Accountable team
P1 — Critical	0–30 days	Restrict cloud sharing; review public links, permissions and sensitive-data controls (R004).	Cloud Security
P2 — High	0–60 days	Enforce MFA; prioritize privileged access; review EHR permissions (R001, R003, R006).	IAM / EHR Owner
P2 — High	30–60 days	Launch recurring phishing simulations; apply secure endpoint baseline and patching (R001, R002).	Security Awareness / Endpoint
P2 — High	30–90 days	Test backup restores; assess immutable/offline backup protection (R005).	IT Operations

Timelines are proposed planning targets, not approved service-level commitments. Owners should confirm feasibility, resources, dependencies, and acceptance criteria before execution.

7 Evidence and validation plan

Suggested authorized evidence: cloud sharing policy exports and permission review records; MFA enforcement reports; EHR access review signoffs; endpoint configuration and patch compliance summaries; phishing training attendance and simulation metrics; backup restore test results. For a real audit, obtain permission, minimize sensitive data, and retain only sanitized evidence.

8 Limitations and conclusion

This is a synthetic educational case study. No MedSecure Solutions entity, employees, patient data, infrastructure, or actual control effectiveness were assessed. The analysis is useful for demonstrating risk documentation, prioritization, and NIST CSF mapping—not for certifying security or regulatory compliance.

The next logical stage is to assign remediation owners, establish due dates, collect authorized evidence, validate implementation, and re-score residual risk after controls are tested.

Source workbooks and references

- 01-Asset-Inventory/MedSecure_Asset_Inventory.xlsx
- 02-Risk-Register/MedSecure_Cybersecurity_Risk_Register.xlsx
- 03-Risk-Matrix/MedSecure_Risk_Matrix.xlsx
- 04-NIST-Control-Mapping/MedSecure_NIST_CSF_2.0_Control_Mapping.xlsx
- NIST Cybersecurity Framework 2.0, NIST CSWP 29: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf
- NIST Cybersecurity Framework: https://www.nist.gov/cyberframework